

DVWA 보안 레벨에 따른 웹 공격 성공률 변화 분석

— SQL 인젝션과 XSS의 방어 양상 비교 —

작성자: 지은 작성일: 2026년 9월 30일 과정: SKT ALEPH 정보보안 과정 (과제 10)

초록 (Abstract)

웹 애플리케이션의 대표적 취약점인 SQL 인젝션과 XSS는 보안 설정 수준에 따라 방어 정도가 달라진다고 알려져 있다. 그러나 “보안 수준을 높이면 공격이 막힌다”는 통념이 공격 종류와 무관하게 동일하게 성립하는지는 분명하지 않다. 본 연구는 교육용 취약 웹 애플리케이션 DVWA의 세 보안 레벨(low, medium, high)에서, SQL 인젝션과 XSS 각각에 대해 기본형과 변형을 포함한 5개씩의 페이로드를 입력하여 공격 성공률을 측정했다. 그 결과 두 공격 모두 low에서 100%, high에서 0%의 성공률을 보여 보안 강화가 공격을 억제함을 확인했다. 그러나 medium 레벨에서 두 공격은 크게 갈렸다. SQL 인젝션은 0%로 완전히 차단된 반면, XSS는 60%가 성공했다. 원인을 분석한 결과 SQL 인젝션 방어는 공격의 핵심 요소인 작은따옴표를 무력화한 반면, XSS 방어는 `<script>` 문자열만 제거하여 이를 쓰지 않는 변형(img, svg, 대소문자 혼용) 공격이 우회에 성공했다. 본 연구는 중간 수준의 보안 설정이 모든 공격에 동일한 보호를 제공하지 않으며, 방어가 특정 문자열만 차단할 경우 변형 공격에 취약함을 실증적으로 보인다.

주제어: DVWA, SQL 인젝션, XSS, 웹 취약점, 보안 레벨, 페이로드

1. 서론

웹 애플리케이션은 사용자 입력을 처리하는 과정에서 다양한 공격에 노출된다. 그중 SQL 인젝션(CWE-89)과 XSS(CWE-79)는 OWASP Top 10에서 인젝션 범주로 함께 다뤄지는 대표적 취약점이다(OWASP, 2021). 이러한 공격을 막기 위해 애플리케이션은 입력 검증, 필터링, 인코딩 등 다양한 방어를 적용하며, 방어 수준이 높을수록 공격이 어려워진다고 여겨진다.

그러나 실무와 교육 현장에서 흔히 통용되는 “보안 수준을 높이면 공격이 막힌다”는 명제는 다소 막연하다. 특히 “중간 수준(medium)”의 보안 설정이 서로 다른 종류의 공격에 대해 동일한 수준의 보호를 제공하는지는 별도의 검증이 필요하다.

본 연구는 이 질문을 교육용 취약 웹 애플리케이션 DVWA(Damn Vulnerable Web Application)를 이용해 실증적으로 검증한다. DVWA는 보안 레벨을 low/medium/high로 조절할 수 있어, 동일한 공격을 서로 다른 방어 수준에서 반복 실행하기에 적합하다(OWASP VWAD; Wood, digininja). 연구 질문은 다음과 같다.

보안 레벨이 올라갈수록 공격 성공률은 낮아지는가? 그리고 그 감소 양상은 공격 종류(SQL 인젝션 vs XSS)에 따라 다른가?

이미 알려진 사실은 SQLi·XSS가 대표적 웹 취약점이라는 점, DVWA가 레벨 조절이 가능한 교육용 도구라는 점, 보안 강화가 공격을 어렵게 한다는 점이다. **본 연구가 새로 주장하는 것**은 같은 medium 레벨이라도 공격 종류에 따라 방어력이 크게 다르며, 그 차이가 방어가 겨냥하는 대상(핵심 요소 vs 특정 문자열)에서 비롯된다는 점이다.

2. 연구 방법

2.1 실험 환경

항목	내용
공격 대상	Metasploitable VM (IP 192.168.10.204) 내장 DVWA
공격 수행	Kali Linux VM, Firefox 브라우저
보안 레벨	low, medium, high (본 버전은 impossible 미포함, 3단계)
실험 일자	2026-09-30
실행 환경	폐쇄망 실습용 VM (외부 비연결)

2.2 실험 설계

- 독립변수(바꾼 조건): 보안 레벨(low/medium/high), 공격 종류(SQLi/XSS)
- 종속변수(측정값): 각 페이로드의 공격 성공 여부(성공=1, 실패=0)
- 고정 조건: 동일한 페이로드 세트, 동일한 입력 지점, 동일 계정(admin)
- 표본: SQLi 5개 + XSS 5개 = 10개 페이로드 × 3레벨 = 30회 시도

2.3 성공/실패 판정 기준 (실험 전 확정)

- SQL 인젝션 성공(1): 원래 조회되지 않아야 할 데이터(다수 사용자 정보 또는 계정/비밀번호)가 화면에 표시됨. 에러·무응답·단일 결과는 실패(0).
- XSS 성공(1): 경고 팝업(alert)이 실제로 실행됨. 코드가 문자열로만 표시되거나 반응이 없으면 실패(0).

2.4 페이로드 목록

SQL 인젝션

#	페이로드	유형	목적
S1	1' OR '1'='1	기본형	항상 참 조건으로 전체 데이터 조회
S2	1' OR '1'='1' --	기본형	뒤 쿼리를 주석 처리해 무효화
S3	1' oR '1'='1	변형	OR 대소문자 혼용으로 필터 우회
S4	1'/**/OR/**/'1'='1	변형	공백 대신 빈 주석 삽입으로 필터 우회
S5	1' UNION SELECT user,password FROM users --	변형(고급)	다른 테이블에서 계정·비밀번호 추출

XSS (Reflected)

#	페이로드	유형	목적
X1	<script>alert(1)</script>	기본형	기본 스크립트 실행

#	페이로드	유형	목적
X2		변형	이미지 오류 이벤트로 script 태그 회피
X3	<ScRiPt>alert(1)</ScRiPt>	변형	대소문자 혼용으로 필터 우회
X4	<svg onload=alert(1)>	변형	svg 로드 이벤트 이용
X5	"><script>alert(1)</script>	변형	앞 태그를 닫고 스크립트 삽입

2.5 재현을 위한 간단 확인 방법

DVWA Security에서 레벨을 설정한 뒤, SQL Injection 및 XSS(Reflected) 메뉴의 입력창에 위 페이로드를 순서대로 입력하고 판정 기준에 따라 성공/실패를 기록한다. 세 레벨에 대해 반복한다.

3. 결과

3.1 원자료

SQL 인젝션

#	low	medium	high
S1	1	0	0
S2	1	0	0
S3	1	0	0
S4	1	0	0
S5	1	0	0

XSS

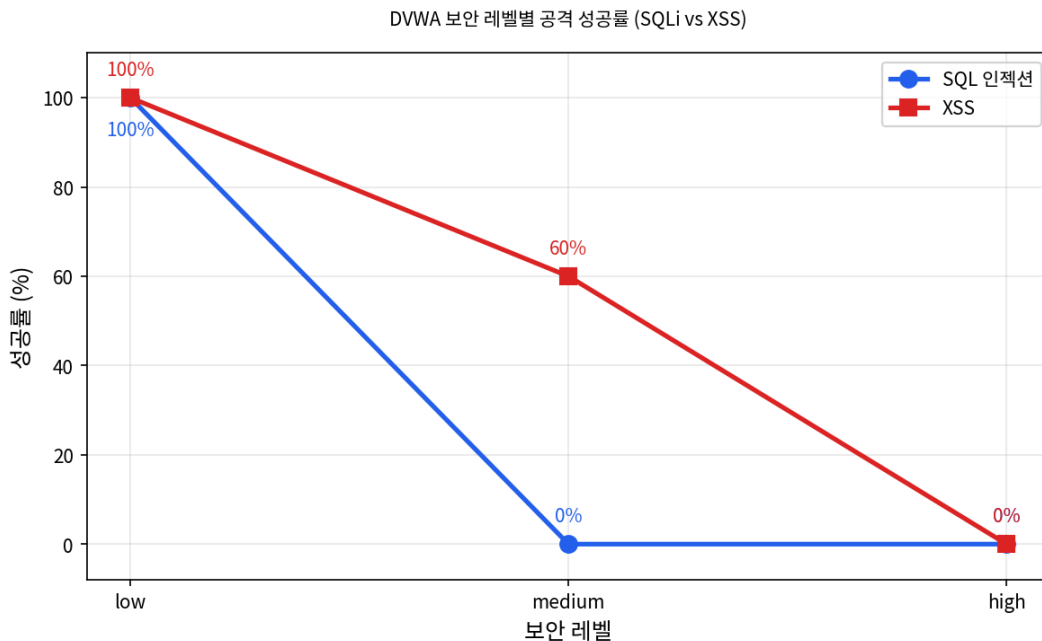
#	low	medium	high
X1	1	0	0
X2	1	1	0
X3	1	1	0
X4	1	1	0
X5	1	0	0

3.2 성공률 요약

보안 레벨	SQL 인젝션	XSS
low	100% (5/5)	100% (5/5)
medium	0% (0/5)	60% (3/5)

보안 레벨	SQL 인젝션	XSS
high	0% (0/5)	0% (0/5)

그림 1. 보안 레벨별 공격 성공률 (SQLi vs XSS)



보안 레벨별 공격 성공률

low·high 레벨에서는 두 공격의 성공률이 동일하지만(각 100%, 0%), medium 레벨에서 SQL 인젝션(0%)과 XSS(60%)가 크게 갈린다.

3.3 주요 관측

- **S1 medium 실패:** SQL 문법 에러가 발생했고, 에러 메시지에서 작은따옴표가 \ ' 로 이스케이프됨을 확인. medium이 작은따옴표를 무력화함.
- **S5 low 성공:** DVWA 기본 계정 5개의 계정명과 비밀번호 해시가 노출됨(공개본에서 생략). 추가로 두 계정의 비밀번호 해시가 동일하여 같은 비밀번호를 쓰고 있음이 확인됨(해시값은 공개본에서 생략).
- **S1 high 실패:** medium과 달리 에러 메시지 없이 무응답. high는 오류 정보를 노출하지 않는 방식으로 방어.
- **X1 medium 실패:** 화면에 Hello alert(1) 가 문자열로 표시됨. medium이 <script> 태그를 제거함.
- **X2·X3·X4 medium 성공:** 각각 img 태그, 대소문자 혼용, svg 태그로 <script> 필터를 우회하여 팝업 실행.

4. 논의

4.1 가설 검증

실험 전 가설은 “보안 레벨이 올라갈수록 공격 성공률이 낮아진다”였다. 결과는 이 큰 방향을 지지한다. 두 공격 모두 low에서 100%, high에서 0%를 기록했기 때문이다. 그러나 “성공률이 레벨마다 점진적으로 낮아진다”는 세부 예상은 성립하지 않았다. SQL 인젝션은 medium에서 즉시 0%로 떨어진 반면(절벽형), XSS는 medium에서 60%가 유지되었다(완만형).

4.2 medium에서 두 공격이 걸린 이유

동일한 medium 레벨에서 SQL 인젝션(0%)과 XSS(60%)의 차이는 방어가 겨냥하는 대상에서 비롯된다. SQL 인젝션 방어는 공격의 **핵심 요소인 작은따옴표 자체를 무력화**하여, 작은따옴표에 의존하는 모든 페이로드를 차단했다. 반면 XSS 방어는 **특정 문자열(<script>)만 제거**하여, 이를 사용하지 않는 변형(img·svg·대소문자 혼용)이 필터를 통과했다.

이 결과는 필터링(블랙리스트)만으로는 XSS를 충분히 막을 수 없으며 출력 인코딩이 필요하다는 OWASP의 권고(OWASP, XSS Prevention Cheat Sheet)와 일치한다. 또한 DVWA의 여러 보안 레벨에서 SQL 인젝션을 분석한 선행 연구(Kumar, 2016)의 관찰과도 부합한다.

4.3 수정된 결론

이상을 종합하여 가설을 다음과 같이 수정한다.

보안 레벨이 올라갈수록 공격 성공률은 낮아지지만, 그 감소 양상은 공격 종류에 따라 다르다. SQL 인젝션은 medium에서 즉시 완전 차단되는 반면, XSS는 medium에서 부분적으로만 차단되어 변형 페이로드로 우회 가능하다.

“중간 수준의 보안”이라는 하나의 설정이 모든 공격에 동일한 보호를 주지 않는다는 점, 그리고 방어가 공격의 핵심 요소가 아니라 특정 문자열만 차단할 경우 변형 공격에 취약하다는 점이 본 연구의 핵심 발견이다.

4.4 한계

- DVWA라는 훈련용 환경의 한 버전만 대상으로 했으므로, 실제 운영 서비스로 일반화할 수 없다.
- 페이로드가 공격당 5개(총 10개)로 제한되어, 더 다양한 변형에서는 결과가 달라질 수 있다.
- 성공/실패(1/0)만 판정했고, 부분 반응 등 중간 상태는 측정하지 않았다.
- high의 0%는 “완벽한 안전”이 아니라 “본 실험의 5개 페이로드로는 뚫지 못함”을 의미하며, 고급 우회 기법은 검증하지 않았다.

5. 참고문헌

1. OWASP (2021). *A03:2021 – Injection*. OWASP Top 10:2021.
https://owasp.org/Top10/2021/A03_2021-Injection/
2. OWASP VWAD. *Damn Vulnerable Web Application - DVWA*. OWASP Vulnerable Web Applications Directory. <https://vwad.owasp.org/app/damn-vulnerable-web-application-dvwa/> (접속일 2026-09-30)
3. Wood, R. (digininja). *Damn Vulnerable Web Application (DVWA)*. GitHub.
<https://github.com/digininja/DVWA> (접속일 2026-09-30)
4. Kumar, A. (2016). *Analysis of Various Levels of Penetration by SQL Injection Technique through DVWA*. JACOTECH The Research Group. academia.edu.
5. OWASP. *Cross Site Scripting Prevention Cheat Sheet*. OWASP Cheat Sheet Series.
https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html (접속일 2026-09-30)